SCHOOL OF ENGINEERING

DAYANANDA SAGAR UNIVERSITY

Devarakaggalahalli, Harohalli Kanakapura Road, Dt, Ramanagara, Karnataka 562112

SCHOOL OF ENGINEERING

Department of Computer Science and Engineering (Cyber Security)

MAJOR PROJECT SYNOPSIS 2026-27

"AuthDrift: Authentication Assurance Drift Detection and Analysis"

by

Name	USN
V Ramya Balaa	ENG23CY0090
Tenzin Tashi	ENG23CY0088
Varun Vilas G	ENG23CY0123
Rohan Appaiah KB	ENG23CY0126

Under the Guidance of
Prof. Sharanabasappa Tadkal

Candidates Name & Signature

1. V Ramya Balaa
2.Tenzin Tashi
3.Varun Vilas G
4.Rohan Appaiah KB

TABLE OF CONTENTS

1. **TITLE OF THE PROJECT**
2. **INTRODUCTION**
3. **PROBLEM STATEMENT**
4. **LITERATURE SURVEY**
5. **OBJECTIVE OF THE PROPOSED WORK**
6. **PROPOSED METHODOLOGY**
7. **EXPECTED OUTCOME OF THE PROPOSED WORK**
8. **SUMMARY**
9. **REFERENCES**

TOPIC

AuthDrift: Authentication Assurance Drift Detection and Analysis

ABSTRACT

Passwordless authentication mechanisms such as passkeys, built on the WebAuthn and FIDO2 standards, are increasingly being adopted in place of traditional passwords because of their resistance to phishing and credential theft. In practice, however, most identity providers still permit fallback to weaker authentication methods, such as passwords or one-time codes, when a passkey attempt fails, is unavailable, or is not supported on a given device. Authentication events such as a failed login, a change in authentication method, or a new device registration are typically logged and analysed independently, which makes it difficult to recognise when a user's overall authentication strength has quietly decreased during a single authentication journey.

This project, AuthDrift, proposes a lightweight, vendor-neutral monitoring layer that reconstructs a user's complete authentication journey and evaluates the change in authentication assurance across that journey. Authentication methods are represented using relative assurance levels, and the sequence and context of events, including method failures, fallback to weaker methods, device changes, location changes, and new authenticator registrations, are correlated to identify authentication assurance drift. When a significant reduction in assurance is detected, the system generates a risk alert along with an explanation of the transitions that led to it. A prototype is proposed using Keycloak as a controlled authentication test environment, a Python-based detection engine, and a web dashboard for visualising authentication timelines, risk levels, and alerts.

INTRODUCTION

Password-based authentication has long been recognised as a weak point in digital security, being vulnerable to phishing, credential reuse, and brute-force attacks. To address these weaknesses, passwordless authentication methods built on the FIDO2 and WebAuthn standards, commonly known as passkeys, have been adopted by major identity providers and platforms. Passkeys use public-key cryptography bound to a specific device or authenticator, which makes them significantly more resistant to phishing and remote credential theft than passwords.

Despite this shift, most authentication systems continue to support fallback mechanisms, such as passwords, one-time passcodes, or email-based verification, to accommodate account recovery,

unsupported devices, or authenticator failures. While necessary for usability and accessibility, these fallback paths reintroduce weaker authentication methods into an otherwise strong authentication ecosystem. A single authentication journey may therefore begin with a strong method and end with a considerably weaker one, without this change being clearly represented as a single security-relevant event.

Existing identity and access management systems generate authentication logs and, in many cases, apply adaptive or risk-based authentication policies. However, these capabilities are largely vendor-specific and focus on individual authentication attempts rather than on how authentication assurance changes across a complete journey. This project explores a lightweight, vendor-neutral approach to correlating authentication events and detecting meaningful degradation in authentication assurance, referred to in this work as authentication drift.

PROBLEM STATEMENT

Modern authentication systems generate a large number of individual events, including successful logins, failed attempts, method changes, device registrations, and location changes. These events are commonly logged and, in some systems, individually risk-scored, but they are rarely analysed together as a connected authentication journey. As a result, a sequence of events that individually appear minor, such as a failed passkey attempt followed by a successful password login from a new device, may not be clearly represented as a single suspicious pattern, even though the combination indicates a meaningful reduction in authentication assurance. There is a need for a lightweight method that can reconstruct a user's authentication journey, model the relative strength of the authentication methods used, and identify suspicious degradation in authentication assurance across that journey, independent of the specific identity provider generating the underlying logs.

LITERATURE SURVEY

The WebAuthn specification, developed by the World Wide Web Consortium, defines an API that allows web applications to use public-key cryptography for user authentication in place of passwords [2]. Together with the FIDO Alliance's Client-to-Authenticator Protocol, WebAuthn forms the FIDO2 standard for passwordless authentication [1]. Barbosa et al. presented a formal security analysis of the FIDO2 protocol, examining the security guarantees provided by WebAuthn and CTAP2 under a defined threat model [6]. More recent work has continued to examine the security and usability of FIDO2 in practical deployments, including an analysis of local attacks such as malicious browser extensions and physical access to hardware security keys [7].

The concept of authentication assurance is addressed in the NIST Digital Identity Guidelines, which describe Authenticator Assurance Levels representing the relative confidence associated with different authentication methods and factor combinations [3]. Identity providers such as Microsoft and Okta implement related concepts in their own platforms, including authentication strength policies and adaptive, risk-based authentication that can request stronger verification when a login attempt is considered unusual [4], [5]. These mechanisms rely on signals such as device, location, and behavioural patterns, but the resulting policies and logs remain largely specific to each identity provider.

Security Information and Event Management (SIEM) platforms and identity and access management (IAM) systems already provide logging, alerting, and, in many cases, correlation of security events across a user session, and are capable of detecting many forms of anomalous authentication behaviour. However, general-purpose event correlation in SIEM and IAM tools is not specifically designed to represent authentication as a changing security state or to explain a degradation in authentication assurance as a single, interpretable event. Existing identity providers already provide authentication logs, adaptive authentication policies, and risk signals; this project does not attempt to replace these capabilities or to identify a new weakness in passkeys or FIDO2 itself.

Instead, the gap this project addresses lies in the correlation layer above these existing sources: reconstructing a user's complete authentication journey from available logs, modelling authentication methods on a common assurance scale, and explaining, in a vendor-neutral manner, why a particular sequence of events represents a meaningful reduction in authentication assurance.

OBJECTIVE OF THE PROPOSED WORK

1. Collect and normalize authentication events from authentication logs.
2. Model authentication methods using relative assurance levels.
3. Reconstruct complete authentication journeys for individual users.
4. Detect suspicious degradation in authentication assurance across a journey.
5. Correlate authentication assurance changes with contextual anomalies such as device and location changes.
6. Generate explainable risk alerts describing the reason for a detected drift.
7. Provide a lightweight, vendor-neutral prototype that can work with logs from different identity providers.

PROPOSED METHODOLOGY

The proposed system follows a sequential pipeline that converts raw authentication logs into an explainable risk alert:

Authentication Logs → Event Normalization → Authentication History / Timeline → Assurance Assignment → State/Sequence Analysis → Drift Detection → Risk Scoring → Explainable Alert → Dashboard

Authentication logs from the identity provider (Keycloak in the prototype) are first normalized into a common event format capturing the authentication method used, the outcome, the device, the approximate location, and the timestamp. These normalized events are grouped per user to reconstruct an authentication history, or timeline, covering a session or a defined time window.

Each authentication method is then assigned a relative assurance level, for example treating a passkey as a high-assurance method and a password as a comparatively low-assurance method. The system analyses the resulting sequence of assurance levels and contextual events to identify transitions where authentication assurance decreases significantly within a short interval, rather than treating each event independently.

When such a transition is detected, a drift score is calculated based on the size of the assurance reduction and the presence of accompanying contextual anomalies, such as a new device, a new location, or a newly registered authenticator. The system then generates a risk alert that states the risk level and explains, in plain terms, which transition and contextual factors led to the alert. A web dashboard displays the authentication timeline, the calculated risk levels, and the generated alerts.

Keycloak is used as a controlled test environment in which normal and suspicious authentication scenarios can be generated for evaluation. Representative scenarios considered during development and testing include:

1. Normal passkey login from a known device.
2. Passkey to password fallback.
3. Passkey failure followed by weaker authentication.
4. Weaker authentication performed from a new device.
5. Authentication downgrade followed by registration of a new authenticator.

EXPECTED OUTCOME OF THE PROPOSED WORK

The expected outcome of this project is a working prototype capable of demonstrating the detection of authentication assurance drift using controlled test scenarios. Specifically, the prototype is expected to:

1. Collect authentication events from a Keycloak-based test environment.
2. Identify suspicious transitions in authentication assurance across a journey.
3. Calculate a risk level for a given authentication journey.
4. Display the reconstructed authentication sequence on a timeline.
5. Explain the reasoning behind a generated risk alert.
6. Demonstrate detection of the scenarios described in the methodology using controlled test data.

As the system has not yet been implemented, no performance figures or detection results are presented at this stage; these will be evaluated once the prototype is built and tested.

SUMMARY

AuthDrift is a lightweight, vendor-neutral monitoring layer that addresses the gap between individual authentication events and the overall security of a user's authentication journey. Rather than treating each login attempt, failure, or device change as an isolated event, the system models authentication methods using relative assurance levels and correlates transitions across a user's journey to identify meaningful degradation in authentication strength, referred to as authentication assurance drift. Using Keycloak as a controlled test environment and a Python-based detection engine, the project aims to build a prototype that reconstructs authentication timelines, calculates risk levels, and generates explainable alerts that can support Security Operations Centre analysts in identifying accounts that may require further verification or intervention. The system is intended to complement, rather than replace, the authentication policies, logs, and risk signals already provided by identity providers.

REFERENCES

[1] FIDO Alliance, “FIDO2: WebAuthn and CTAP,” FIDO Alliance. [Online]. Available: https://fidoalliance.org/fido2/

[2] World Wide Web Consortium (W3C), “Web Authentication: An API for Accessing Public Key Credentials Level 2 (WebAuthn),” W3C Recommendation. [Online]. Available: https://www.w3.org/TR/webauthn-2/

[3] National Institute of Standards and Technology, “Digital Identity Guidelines: Authentication and Authenticator Management,” NIST Special Publication 800-63B.

[4] Microsoft, “Authentication Strengths and Passkey Support in Microsoft Entra ID,” Microsoft Learn Documentation.

[5] Okta, “Adaptive Multi-Factor Authentication and Authentication Policies,” Okta Developer Documentation.

[6] M. Barbosa, A. Boldyreva, S. Chen, and B. Warinschi, “Provable Security Analysis of FIDO2,” in Advances in Cryptology – CRYPTO 2021, LNCS vol. 12827, Springer, pp. 125–156, 2021.

[7] T. K. Yadav and K. Seamons, “A Security and Usability Analysis of Local Attacks Against FIDO2,” in Proceedings of the Network and Distributed System Security Symposium (NDSS), 2024.

Guide Signature **Project Coordinator** **Academic Co-ordinator**

(_____) **(Dr. D. Sumathi)**

Forwarded through Dept. Chairman
(Dr.Dilip Kumar Jang Bahadur Saini)